Forensics Case Study

Ramiz Aliguliyev

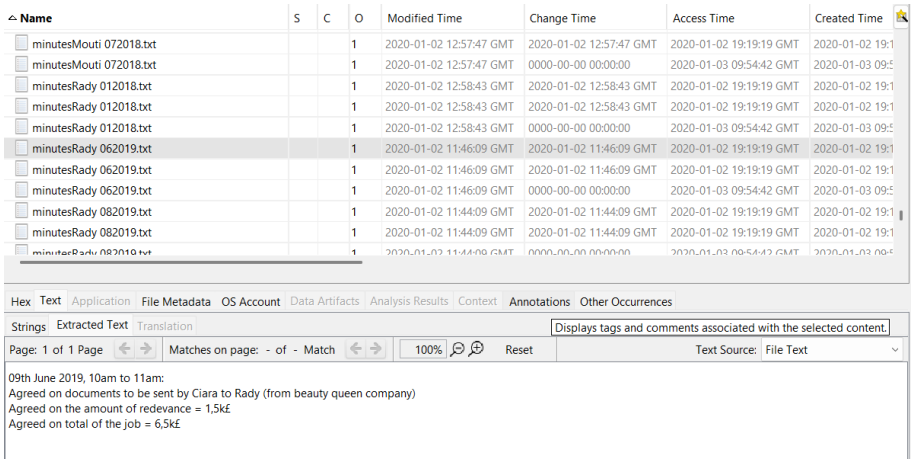
COM6016 Cyber Threat Hunting and Digital Forensics

The University of Sheffield

1. Disk Image Investigation

Suspicious personal files

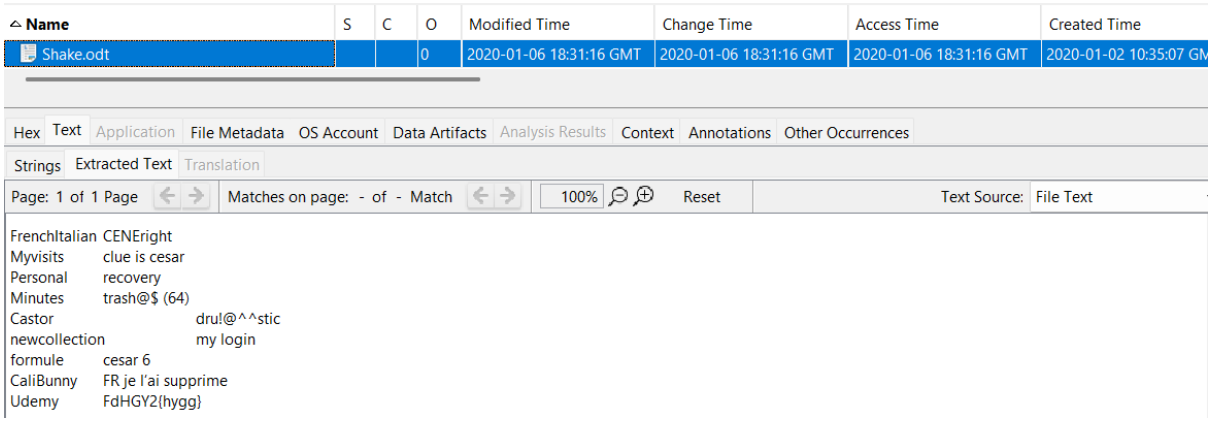
Files that look suspicious Ciara worked as a Product Manager at Philotess. An analysis of her disc image found several files with personal information about identifiable people, such as names, time periods, and financial information. This seems strange and possibly inappropriate for storage on a workstation connected to a product management role.



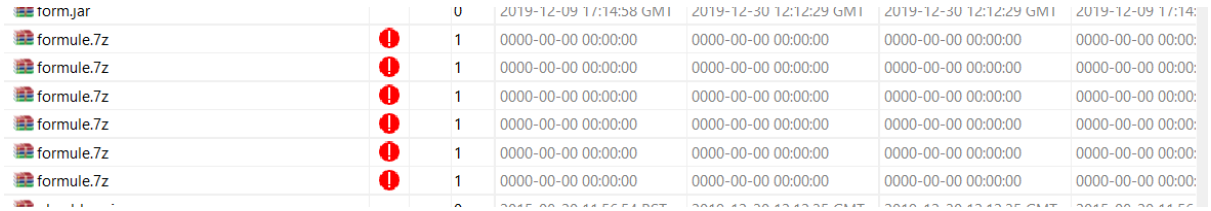
Password file And 7z

A shortcut file called shake.odt.lnk was found in the list of recent files. This means that the document Shake.odt can be opened. This analysis of the artefact reveals that the document may have had personal notes or private information in it, such as parts that look like passwords or terminology relating to recovery. Also, the inclusion of phrases like "minutes" and entries like "trash$" (64) matches up with other supporting files that have already been found, such as minutes.Rady and minutesMouti shows a trend of

including meeting-related or sensitive information in documents made by users.



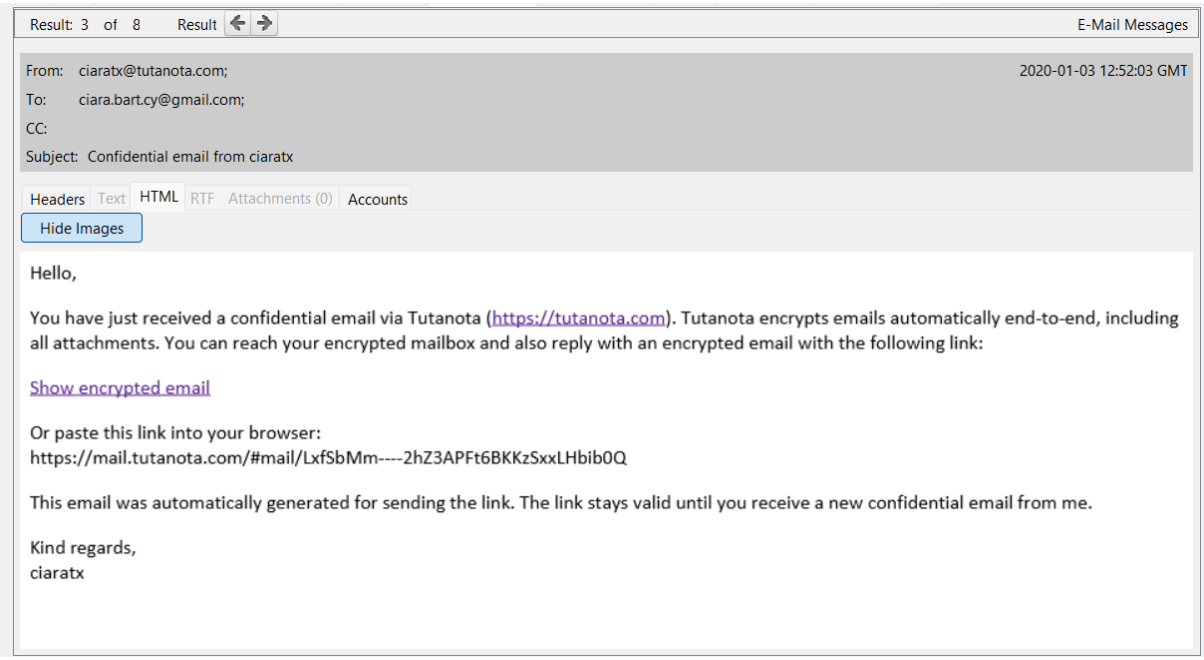
A corrupted 7z archive called "formula" was found on the disc image, which is more proof.The document Shake.odt had a reference to "cesar 6," which seems to mean that a Caesar cypher with a shift of six was used to hide the information. This connection shows that the archive was purposely protected with a weak cipher-based system, which supports the idea that sensitive data was intentionally hidden rather than stored by accident.

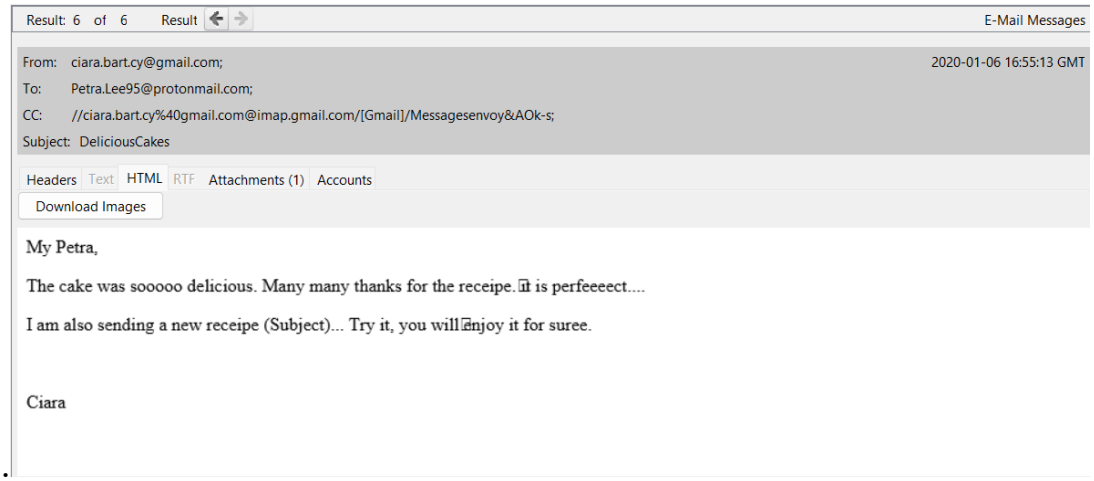


Cesar Cipher

Ciara was found to be utilising Tutanota, a personal, end-to-end encrypted email service, to send business-related messages outside of official company channels. This shows that she was using encrypted external communication tools that were not part of the organisation's normal email system. Ciara sent an email from her personal Gmail account to petra@protonmail.com with the subject line "DeliciousCakes" and the body of the email as a "cake recipe." We used a Caesar cypher with a shift of six to get the

decoded output "Jkroiouaylgqky," which supports the idea that the subject line was a hidden reference to the formula.7z file for extraction.

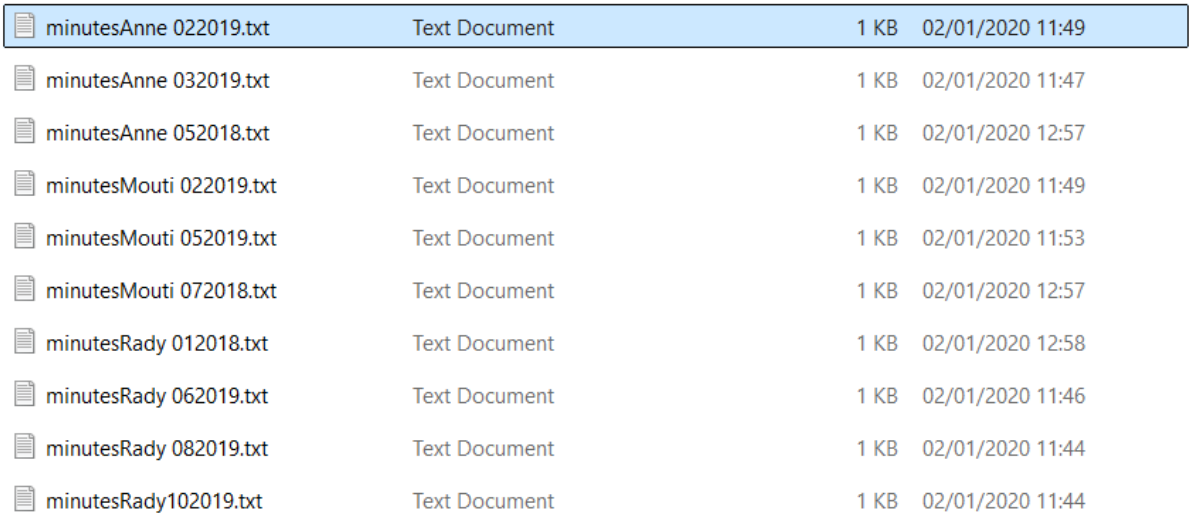




	dose
1	30 g
2	5 g
3	12 ml
4	2
5	21 g

Minutes.7z

Also, the disc image showed a compressed archive called Minutes.7z, which seemed to hold a lot of personal and business-related information. The document Shake.odt showed that this archive included a password reference, and when the archive was opened, it was found to have a file that was much more compressed and held more sensitive information. This conclusion indicates intentional aggregation and stratified storage of sensitive material, as opposed to inadvertent file retention.



Task 2: Incident Response Analysis

Data from web application logs, firewall logs, and SIEM alerts are collected on June 28, 2025, and are utilized to investigate two interrelated security events. The investigation clarifies the timeline of events during the incidents, marks security-relevant events together with Indicators of Attack (IOAs), ranks threats, and offers incident response measures. By correlating Events 1 and 2, it will be possible to know if the activity detected was a single point of an attack or part of a larger security breach.

Event 1: Firewall and Web Application Logs

What is going on?

The analysis of firewall logs shows that there is a continuous hostile external activity against the internal systems. The repeated blocked inbound HTTP requests coming from a single external IP address within a very short time frame point out very strongly to either an automated reconnaissance or denial-of-service attack. Such events indicate that the network perimeter of the organization was being attacked very actively during the early morning hours. From the application point of view, most of the users' activities are in line with the normal operating business; however, there are some anomalies. The most noticeable ones are faintly the same account being changed passwords repeatedly and an external IP address making multiple failed login attempts that deviate from the expected behavior. The biggest event is the case where external login attempts have been unsuccessful but soon after that, there is a successful authentication and a consequent export of roughly 1GB of customer data which signals a possible data breach

Security-Relevant Events and Justification

The quantity and rate of blocked incoming requests are typical for an automated attack and this traffic is accordingly classified as a security risk. Similarly, outgoing connections from inside the organization to dubious external IP addresses are still regarded as a security risk since they might signify an attempt to move or have a command-and-control. Unusual password-change frequency and important data export activity are very essential from the application point of view due to their influence on confidentiality and possible legal issues. The risk that could be accepted has already been surpassed by this chain of events, hence an urgent inquiry is necessary.

Indicators of Attack (IOAs)

The first event revealed a lot of IOAs among which the most important ones were high-frequency repeated requests, multiple failed authentication attempts followed by successful access, logins from external or known malicious IP addresses and huge data exports that were not in line with the normal user role. The weighted presence of these factors leads to the conclusion of malevolent intent over accidental misuse.

Incident Response Approach

The normal process of incident response should start with containment, which includes the suspension of user accounts that have been affected, the blocking of the IP addresses that are malicious, and the isolation of internal hosts that are showing suspicious outbound traffic. The next step will be to eradicate by doing credential resets, scanning of the affected systems for malware and checking access rights. Recovery will be done by restoring services under the enhanced monitoring and data

integrity being verified. The actions taken after the incident should be aimed at making the detection of the abnormal user behaviour better, especially in the case of large data exports and credential misuse.

Event 2: SIEM Alerts

Detected and Potentially Undetected Threats

The Security Information and Event Management (SIEM) system has detected many network-based potential threats and these include SSH brute-force attempts, SYN flood activities, and suspicious outbound connections on uncommon ports. The alerts indicate that perimeter security precautions were able to detect and block noisome external attacks effectively.

On the other hand, the SIEM alerts have also made it clear that possible threats might exist which might not be detected. Initially, activities of legitimate credentials like logged-in users accessing sensitive information were not regarded as serious. This signals a flaw in the detection process of behavioral monitoring, where attacks using stolen credentials can easily bypass conventional signature-based alerting mechanisms.

Alert Prioritization and Most Dangerous Attack Type

From the alerts that are related to unusual outbound traffic and suspected data exfiltration, those are to be given priority for further investigation. Denial-of-service and brute-force attacks, though, affect availability and are usually of non-duration and also easy to detect. In the other hand, data exfiltration via compromised credentials

presents the biggest threat because of the impact on confidentiality and the possibility of slow detection. Hence, credential misuse permitting unauthorized access to the data is the most dangerous attack type that has been noticed.

First Three Actions at 08:00 on 28-06-2025

In case of a reply at 08:00 on the same day, the very first step would be to match SIEM alerts with firewall and application logs to detect impacted users, systems, and IPs. The second step would be the immediate suspension or limitation of accounts associated with the suspicious activity in order to stop any further data leaks. The third step would be the collection of forensic evidence, such as logs and states of systems, meant for thorough investigation, and thus, the integrity of the evidence will be upheld.

Correlation Between Event 1 and Event 2

Events 1 and 2 are evidently related to one another. The firewalls and SIEM systems detected the external scanning, brute-force attempts, and denial-of-service activities and these were followed by application-layer anomalies related to the misuse of credentials and the export of data. Hence the case points to a multi-stage incident where the external attack activities might have led to the compromising of the credentials which further allowed a cycle of unauthorized access and data exfiltration.

2.4 Timeline of Key Events

Time (2025-06-28)	Event
01:12–01:13	Sustained blocked inbound requests indicate scanning/DoS activity
01:15	SIEM detects multiple failed SSH login attempts
02:30	Unusual outbound traffic detected from an internal host

03:15	SYN flood alert targeting an internal system
19:00–19:20	Failed logins from external known bad IP
19:20–19:30	Successful login followed by large data export

Task 3: Network Forensics Analysis

The network forensic examination of the recorded packets pertaining to Task 3 is the subject of this endeavour. The analysis of the packet sequence, detection of unusual network activities, and presence of possible types of communication in the network are the main objectives. The scrutiny of the traffic patterns, determination of TCP flags, counting retransmissions, and communication characteristic tracing through Wireshark are the main methods on which the analysis is conducted.

3.2 Packet Capture Overview

A thorough examination of the captured packet revealed that there was an unusually high number of TCP SYN packets coming from a single source host and directed to a destination host within the network. These packets were typical of persistent TCP connection attempts that did not lead to complete TCP three-way handshakes. Wireshark identified a considerable number of packets as TCP retransmissions which signal repeated connection initiation attempts that did not receive successful acknowledgements. The traffic is smooth mostly regarding its size and structure with the TCP parameters of sequence number, window size and MSS being the same all through. This strong repetition is a clear indication of automated behavior rather than genuine application traffic. Moreover, no signs of continuous data transfer or TCP

sessions have been established which further solidifies the argument that the traffic is not related to normal client-server communication.

3.3 Analysis of Suspicious Behavior

The fact that there are many TCP SYN packets sent without getting back any SYN-ACK signals is a solid proof for TCP scanning activity. In a normal network conversation, a SYN packet would normally be followed by a SYN-ACK from the destination and then an ACK from the source, thus completing the handshake. The repeated retransmissions in this case mean that the destination is either not responding or is actively rejecting the connection attempts. The behavior of the source IP address being the only one from which the activity is coming, and that too for a long time, suggests that the source was intentionally probing the network rather than the cause being random packet loss or network misconfiguration. This kind of activity is similar to one of the common reconnaissance techniques which are used to detect open ports or active hosts before exploitation. The presence of no payload data and the emphasis on connection initiation are further evidences of a scan rather than a denial-of-service attack, which would typically involve a much higher packet rate or multiple distributed sources.

3.4 Interpretation and Indicators of Attack

The sequence of packets reveals a TCP SYN scan on the network possibly designed to map out the services that are running on the target machine. The main signs that back this conclusion are the frequent SYN retransmissions, non-existence of finished handshakes, consistent packet formation and a single source of scanning. These signs are typical of the attackers' reconnaissance which is done in the first phase of the

intrusion lifecycle. Although this capture does not show any indication of successful exploitation or data exfiltration, reconnaissance activity is a necessary condition for more serious attacks. If such scanning goes unnoticed, it may result in the encouraging of the exploitation of the service with the least security.